Contents

ASVS Conformance Target **1**
Levels, briefly . . . 1
Scope . . . 1
Why not Level 2 everywhere . . . 3
Where each chapter is implemented . . . 3
Verification . . . 4
Status — evidenced 2026-10-04 (SPEC-027) . . . 4
What this evidence pass changed about the claim . . . 15
Related . . . 15

ASVS Conformance Target

Which parts of the OWASP Application Security Verification Standard this project commits to, at which level, and why. Decision: [[ADR-0009-code-quality-gates]].

Source: ASVS **5.0.0**, vendored verbatim in `upstream/asvs-5.0.0/` — see [[owasp-provenance]]. Requirements are referenced by id. Their text is in the upstream CSV and JSON, not copied here.

Levels, briefly

Level	Meaning
L1	the baseline every application should meet
L2	applications handling meaningful personal data or transactions
L3	high-assurance systems

Scope

345 requirements across 17 chapters. This project commits to **142** of them.

Ch	Chapter	L1	L2	L3	Committed	Rationale
V1	Encoding and Sanitization	8	19	3	**L1**	user-supplied text reaches the database and other users' screens
V2	Validation and Business Logic	4	7	2	**L1**	vote and licence rules are business logic with abuse potential

Ch	Chapter	L1	L2	L3	Committed	Rationale
V3	Web Frontend Security	8	11	12	*conditional*	no web frontend today; becomes L1 if the responsive-web bonus is built
V4	API and Web Service	2	8	6	**L1**	the API is the entire attack surface
V5	File Handling	4	5	4	**L1**	no uploads are designed, but profile imagery would land here
V6	Authentication	13	22	12	**L2**	subject V.1 and V.6 grade this directly
V7	Session Management	6	12	1	**L2**	subject V.6 names session hijacking explicitly
V8	Authorization	4	3	6	**L2**	subject V.6: a user reaches own data only; plus visibility and licence gates
V9	Self-contained Tokens	4	3	0	**L2**	we issue JWTs ourselves
V10	OAuth and OIDC	5	24	7	**L2**	Google and Facebook sign-in — [[ADR-0008-oidc-social-login]]
V11	Cryptography	3	11	10	**L1**	password hashing, token signing — [[ADR-0007-password-hashing-bcrypt]]

Ch	Chapter	L1	L2	L3	Committed	Rationale
V12	Secure Communication	3	6	3	**L1**	HTTPS and WebSocket over TLS
V13	Configuration	1	12	8	**L1**	`.env` discipline, subject V.8
V14	Data Protection	2	7	4	**L1**	three profile visibility tiers hold personal data
V15	Secure Coding and Architecture	3	10	8	**L1**	dependency and coding hygiene
V16	Security Logging and Error Handling	0	16	1	**L2**	the mandatory audit log is subject V.6; there are no L1 rows in this chapter
V17	WebRTC	0	7	5	**out of scope**	no peer-to-peer media; playback is client-side YouTube

Committed = 62 L1 requirements (all chapters except V3 and V17) + 80 L2 requirements (V6, V7, V8, V9, V10, V16).

Why not Level 2 everywhere

A conformance claim you cannot demonstrate is worth less than a narrower one you can. L2 is committed exactly where subject V.6 is graded and where this system's real risk sits: identity, sessions, tokens, authorization, federated login, and the audit trail. Claiming L2 across all 17 chapters would mean claiming 183 verified requirements that no one on this team has verified.

State this reasoning at defence. "We chose our scope and can show it" beats "we ticked everything".

Where each chapter is implemented

Chapter	Primary implementation	Rules
V1, V2	FluentValidation in the pipeline; EF Core parameterised queries	[[application-security]]
V4	REST contract, Problem Details, pagination caps	[[rest-api-design]]
V6, V7, V9	BCrypt, JWT + rotating refresh tokens, revocation	[[authentication-authorization]]
V8	the two authorisation gates, evaluated in a pipeline behaviour	[[sdd]] §13.2

Chapter	Primary implementation	Rules
V10	authorization code + PKCE, server-side ID token validation	[[social-oauth]]
V11	BCrypt work factor, JWT signing key from `.env`	[[ADR-0007-password-hashing-bcrypt]]
V12	HTTPS, HSTS, TLS for the SignalR transport	[[application-security]]
V13	`.env`, `.env.example`, no secret in source or image	[[secrets-management]]
V14	per-field profile filtering, soft delete, data minimisation	[[sdd]] §13.2
V15	analyzers, size limits, vulnerable-dependency scan	[[dotnet-csharp]], [[ci-cd-containerization]]
V16	the audit table, structured logging, the never-logged list	[[logging-observability]]

Verification

A requirement counts as met when there is **evidence**, not intent:

Evidence	Example
a test	the negative authorisation test for V8
an analyzer rule	the vulnerable-package scan for V15
a configuration artifact	`.env.example` and the ignore rule for V13
a design element plus a code path	the audit behaviour for V16

Unmet requirements are not deleted from this table. They go to [[threat-register]] with their residual risk.

Status — evidenced 2026-10-04 (SPEC-027)

The sentence that used to be here said no code existed. Eight slices later, this is the evidence pass.

	Count
Committed	**142** (62 L1 + 80 L2, recomputed from the vendored CSV)
Met, with a named test, code path or configuration file	**63**
Partial — something exists, something named is missing	**5**
Not met	**50**, of which 29 are V10 waiting on S8 and 3 are TLS waiting on a deployment
Not applicable, with the reason stated	**24**

Four outcomes, and each row carries an artifact or a reason. A row closed by writing documentation says so: ASVS asks in several places that *documentation define* a rule, and the definition is the work — but a reader deserves to know which rows a sentence closed and which a test did.

V1 Encoding and Sanitization — L1, 8 committed

Req	Outcome	Evidence
V1.2.1	met	responses are JSON written by `System.Text.Json`, which escapes on serialisation; no endpoint builds HTML or XML
V1.2.2	met	`CredentialMailTemplates.Link` builds the one dynamic URL this system makes, with `Uri.EscapeDataString` on the token
V1.2.3	met	no JavaScript is generated; the mail bodies that embed a value run it through `WebUtility.HtmlEncode` (`CredentialMailTemplates.Build`)
V1.2.4	met	every query is EF Core LINQ or `ExecuteUpdateAsync`/`ExecuteDeleteAsync`; the one raw statement, the load seed's `seed.sh`, is a developer tool outside the solution
V1.2.5	not applicable	the application makes no OS calls
V1.3.1	not applicable	no WYSIWYG editor and no HTML input anywhere in the contract
V1.3.2	met	no `eval`-equivalent: no dynamic code execution, no expression language, no reflection over user input
V1.5.1	not applicable	no XML parser is configured or reachable; the API is JSON only

V2 Validation and Business Logic — L1, 4 committed

Req	Outcome	Evidence
V2.1.1	met, by documentation	the rules are the FluentValidation validators, one per command, and [[application-security]] states the posture: validate at the boundary, refuse rather than coerce
V2.2.1	met	positive validation in every validator — `RegisterCommandValidator` (12–64 characters and 72 UTF-8 bytes), the 11-character YouTube id pattern in `AddTrackCommandValidator`, the licence and window rules in `EventLicenceRules`

Req	Outcome	Evidence
V2.2.2	met	validation runs in `ValidationBehaviour`, inside the server pipeline, and SPEC-025 proved the failure mode of forgetting it: an **internal** validator is never registered, so a blank catalog search answered `200` until it was made public
V2.3.1	met	step order is arbitrated by the database, not by trust: `consumed_at_utc IS NULL AND expires_at_utc > @now` conditional updates for verification and reset, the filtered unique index for one live playback session, `EventVoteConcurrencyTests` and `PlaylistTrackConcurrencyTests` for the contended paths

V4 API and Web Service — L1, 2 committed

Req	Outcome	Evidence
V4.1.1	met	minimal APIs set `application/json`; refusals go through `AddProblemDetails()` and carry `application/problem+json`. No endpoint writes its own content type
V4.4.1	**not met**	the SignalR transport is plain HTTP locally. WSS needs a deployment that terminates TLS — issue **O11**

V5 File Handling — L1, 4 committed

All four **not applicable**: nothing in the contract accepts a file, generates one from untrusted input, or builds a path from a submitted name. Profile imagery would land here and is not designed.

V6 Authentication — L2, 35 committed

Req	Outcome	Evidence
V6.1.1	met, by documentation	[[sdd]] §13.3: the per-IP and per-account numbers and the `429` with `Retry-After`. The realtime ceilings of [[ADR-0030-hub-rate-limits-and-origin]] are documented there too and are **in review, not on `main`** as this is written (SPEC-026)
V6.1.2	**not met**	no context-specific word list exists — **T-32**
V6.1.3	met, by documentation	two pathways: password (built) and OIDC (designed, S8 — [[ADR-0008-oidc-social-login]], [[ADR-0031-musicroom-as-openid-provider]]). Both are named in [[endpoint-inventory]] §1 and nothing else authenticates
V6.2.1	met	`RegisterCommandValidator`: minimum 12 characters, above the 8 required
V6.2.2	**not met**	there is no authenticated change-password endpoint. The reset flow is the only way to replace a password — **T-31**
V6.2.3	**not met**	same gap: no change endpoint, so no current-password check — **T-31**
V6.2.4	**not met**	no breached-password check at registration — **T-32**
V6.2.5	met	no composition rules: the validator constrains length and UTF-8 bytes only
V6.2.6	not applicable	server-side API; `type=password` is a client concern and `MusicRoomApp/` is empty
V6.2.7	not applicable	the same — nothing server-side can block paste
V6.2.8	met	the password is hashed exactly as received. `RegisterCommandHandler` trims and lower-cases the **email** and the display name, and never touches the password
V6.2.9	met	the maximum is 64 characters, so a 64-character password is accepted; the 72-byte ceiling is BCrypt's own truncation point, stated in the validator
V6.2.10	met	no rotation is forced: nothing expires a password, and [[sdd]] §13.1 says so (NIST SP 800-63B)
V6.2.11	**not met**	the list in V6.1.2 does not exist, so nothing uses it — **T-32**

Req	Outcome	Evidence
V6.2.12	**not met**	no breached-password set is consulted — **T-32**
V6.3.1	met	`CredentialRateLimitingTests` and `CredentialAttemptLimiterTests`: per-IP policies per endpoint, a per-account counter with a doubling penalty, and `429` with `Retry-After`
V6.3.2	met	no account is seeded. The only way a row enters `users` is registration, and `SchemaConventionTests` holds the model; the load seed writes rows against a throwaway database and is outside the solution
V6.3.3	**not met**	no second factor. Single-factor password authentication only
V6.3.4	met, by documentation	the two pathways of V6.1.3 are the only ones; `BearerValidationTests` proves an unauthenticated caller reaches nothing
V6.4.1	met	`EmailVerificationEndpointTests` and `PasswordResetEndpointTests`: 256-bit tokens from `RandomNumberGenerator`, stored as SHA-256 digests, single-use through a conditional update
V6.4.2	met	no hints and no secret questions exist in the contract
V6.4.3	met	`PasswordResetEndpointTests`: a one-hour single-use token, every refresh family revoked in the same transaction as the new hash, and `410`/`400`/`422` answers that never describe the token
V6.4.4	not applicable	no second factor exists to lose
V6.5.1 to V6.5.5	not applicable	no lookup secrets, no out-of-band codes, no TOTP. The venue code of [[ADR-0014-location-time-licence]] is an **authorisation** proof for a licence check, not an authentication factor, and carries its own per-account limit
V6.6.1 to V6.6.3	not applicable	no PSTN, no SMS, no out-of-band channel

Req	Outcome	Evidence
V6.8.1 to V6.8.4	**not met**	the IdP surface is S8. V6.8.2 is partially true today — `AddJwtBearer` validates the signature of the tokens this service issues — but the requirement is about assertions from a separate IdP, and there is none

V7 Session Management — L2, 18 committed

Req	Outcome	Evidence
V7.1.1	met, by documentation	[[sdd]] §13.1: a 15-minute access token, 30 seconds of permitted clock skew, and a 30-day **absolute** refresh family lifetime that rotation does not extend
V7.1.2	met, by documentation	concurrent sessions are **not** capped: one account may hold as many refresh families as it signs in, each independently revocable. The bound is the family lifetime, and `GET /auth/sessions` plus `DELETE /auth/sessions/{sessionId}` let a user see and end them. The realtime transport is capped separately — 5 connections per account, in review as SPEC-026 and not on `main` as this is written
V7.1.3	**not met**	federated session management arrives with S8
V7.2.1	met	`BearerValidationTests`: every token is verified by the API itself, signature, issuer, audience and lifetime
V7.2.2	met	`LoginEndpointTests`: a self-contained JWT plus an opaque refresh token, both generated per sign-in
V7.2.3	met	`SessionRotationEndpointTests`: refresh tokens are 256-bit values from `RandomNumberGenerator`, stored only as digests
V7.2.4	met	`SessionRotationEndpointTests`: every rotation issues a new token and consumes the old one in one conditional update; 20 concurrent rotations produce exactly one 200

Req	Outcome	Evidence
V7.3.1	partial	the 15-minute access token is the inactivity bound in practice, but nothing tracks idleness on the refresh family: a client that rotates every 14 minutes stays signed in for the full 30 days
V7.3.2	met	the absolute 30-day family lifetime, inherited by every rotation
V7.4.1	met	`SessionEndpointTests.Logout_ThenRotatingTh`
V7.4.2	partial	a deleted account's rows are soft-deleted behind a global query filter, so its sessions stop resolving — but no code path explicitly revokes the families, and no test asserts it
V7.4.3	met	`PasswordResetEndpointTests.Reset_WithTheIs`
V7.4.4	not applicable	a server-side API has no pages; logout is `DELETE /auth/sessions/current`
V7.4.5	**not met**	there is no administrator role and no administrative surface
V7.5.1	**not met**	no step-up re-authentication: `PATCH /me/profile` needs a valid access token and nothing more
V7.5.2	met	`SessionEndpointTests`: `GET /auth/sessions` lists them and `DELETE /auth/sessions/{sessionId}` ends one. The second factor the requirement mentions does not exist (V6.3.3)
V7.6.1	**not met**	S8
V7.6.2	met	a session is created only by `POST /auth/sessions` with credentials; nothing creates one for an anonymous caller

V8 Authorization — L2, 7 committed

Req	Outcome	Evidence
V8.1.1	met, by documentation	[[sdd]] §13.2 and its table of where each gate lives: ownership, then visibility and licence
V8.1.2	met, by documentation	[[sdd]] §13.2 and §6.2: the three profile tiers are field-level rules, and the projection decides them in SQL

Req	Outcome	Evidence
V8.2.1	met	`PlaylistAccessEndpointTests`, `EventAccessEndpointTests`, `DeviceControlEndpointTests`: a caller without permission is answered `404`, never `403`, so the refusal is not an existence oracle
V8.2.2	met	the same suites, per object: a playlist, event or device the caller may not see cannot be read or written
V8.2.3	met	`UserProfileEndpointTests`: a field whose tier the reader does not clear is absent from the response, and a removed friendship hides it again on the next read
V8.3.1	met	every gate is a handler or repository decision; `PlaylistHubTests` and `EventHubTests` prove the hub re-asks the same gate on join, so the realtime transport is not a way around it
V8.4.1	not applicable	single-tenant

V9 Self-contained Tokens — L2, 7 committed

Req	Outcome	Evidence
V9.1.1	met	`BearerValidationTests`: a tampered token is `401`
V9.1.2	met	`JwtAccessTokenIssuer` signs HS256 and the handler accepts that algorithm only; `JwtOptions` enforces a 32-byte key floor
V9.1.3	met	the key comes from `JWT_SIGNING_KEY` at start-up and the host refuses to boot without it — `EnvironmentConfiguration.RequireJwtOptions`
V9.2.1	met	`BearerValidationTests.Sessions_WithAnExpir` with the 30-second skew stated in [[sdd]] §13.1
V9.2.2	partial	the access token is the only token type this service issues and accepts, so there is nothing to confuse it with — but no explicit `typ` or purpose claim is validated. S8 introduces an ID token, which is when this becomes a real distinction

Req	Outcome	Evidence
V9.2.3	met	`BearerValidationTests`: issuer and audience are both validated, and a token minted for another audience is `401`
V9.2.4	not applicable	one audience today; S8's provider work is where this starts to apply

V10 OAuth and OIDC — L2, 29 committed

Not met, all 29. No social or provider endpoint exists: `POST /auth/sessions/social` and the provider surface are designed in [[ADR-0008-oidc-social-login]] and [[ADR-0031-musicroom-as-openid-provider]] and built at **S8**. Listed here rather than dropped from the count, because a conformance claim that quietly excludes a chapter it committed to is the kind a defence finds.

V11 Cryptography — L1, 3 committed

Req	Outcome	Evidence
V11.3.1	not applicable	nothing in this system encrypts: there is no block cipher use to configure
V11.3.2	not applicable	the same
V11.4.1	met	BCrypt at cost 12 for passwords ([[ADR-0007-password-hashing-bcrypt]], `BCryptPasswordHasherTests`), SHA-256 for the verification, reset and refresh digests, HMAC-SHA256 for the JWT, and `RandomNumberGenerator` for every token

V12 Secure Communication — L1, 3 committed

All three **not met**, and for one reason: nothing is deployed, so nothing terminates TLS — issue **O11**. The container serves plain HTTP on 8080 and the compose stack has no reverse proxy. The code is transport-agnostic, which is not the same as the requirement being met.

V13 Configuration — L1, 1 committed

Req	Outcome	Evidence
V13.4.1	met	`MusicRoom/.dockerignore` excludes `.git/` and `.github/`, and `.env`, `.env.*`, `*.pem` and `*.key` with it; only `.env.example` is allowed through

V14 Data Protection — L1, 2 committed

Req	Outcome	Evidence
V14.2.1	partial	every credential and every token travels in a body or an `Authorization` header — except the hub handshake, where the access token is a **query parameter**. That is SignalR's documented mechanism, it is read only under `/hubs` (SPEC-016 decision 4), and it is the accepted residual **T-30**
V14.3.1	not applicable	no browser client exists to clear storage for; `Clear-Site-Data` has nothing to act on until the web bonus is built

V15 Secure Coding and Architecture — L1, 3 committed

Req	Outcome	Evidence
V15.1.1	met, by documentation	**the policy, stated here:** a vulnerable dependency with a known fix is updated before the next unit of work lands, and `make agent-check` fails the build on any `dotnet list package --vulnerable` hit, so the timeframe is enforced by the gate rather than by a calendar. A vulnerability with no fix available goes to the register with its exposure
V15.2.1	met	the vulnerable-package scan inside `make agent-check`, which has to pass before anything is committed
V15.3.1	met	reads project to explicit records — `PlaylistSummary`, `QueueEntry`, `TrackMetadata`, the profile projection — and `UserProfileEndpointTests` proves a hidden field never leaves the database

V16 Security Logging and Error Handling — L2, 16 committed

Req	Outcome	Evidence
V16.1.1	met, by documentation	the log inventory in [[sdd]] §13.4

Req	Outcome	Evidence
V16.2.1	met	`AuditRecordEndpointTests`: when, who, what, on what, from which platform, device and app version, with a correlation id
V16.2.2	met	audit rows are UTC `timestamp with time zone`, and Serilog's `CompactJsonFormatter` writes `@t` in UTC
V16.2.3	met	one sink, the console in CLEF, as the inventory says; nothing writes a second log file
V16.2.4	met	CLEF is a documented common format, which is what makes `docker compose logs` greppable and the load report's quota lines readable
V16.2.5	met	the never-logged list in [[application-security]], enforced by tests: `LoggingMailServiceTests` for what the Development sender may log, `BrevoMailServiceTests` for the token and key appearing in no log event, `CredentialRateLimitingTests` for a limiter trip naming no account
V16.3.1	met	`AuditRecordEndpointTests`: successful and failed sign-in both leave a row, with `refused`, `throttled`, `expired` and `reusedetected` distinguishing why
V16.3.2	partial	credential refusals are audited; an authorisation denial on a resource route answers `404` and leaves **no** audit row. SPEC-009 recorded this as arriving with the gates, and the gates arrived without it
V16.3.3	met	the security events of [[owasp-top10-checklist]] A09 are the rows above, plus the rate-limit trip; the hub refusals are SPEC-026's and are in review, not on `main` as this is written
V16.3.4	met	`UseSerilogRequestLogging` logs an unhandled exception with its stack; SPEC-023's run is the worked example — 10 874 `53300` lines are what found the connection ceiling

Req	Outcome	Evidence
V16.4.1	met	every log call is a Serilog message **template** with values as properties, and the JSON formatter escapes them; no log line is built by concatenation
V16.4.2	**not met**	logs go to container stdout. Nothing restricts who can read them and nothing makes them immutable — **T-33**
V16.4.3	**not met**	nothing ships logs anywhere. The OpenTelemetry exporter exists and is off by default (issue **O16**) — **T-33**
V16.5.1	met	`AddProblemDetails()` answers a generic problem document; the developer exception page is Development-only, and the refusal bodies are deliberately empty or generic so they say nothing about which key tripped
V16.5.2	met	the catalog degrades rather than failing: a stale `track_refs` row is served when YouTube is unreachable, `503` is answered rather than `500`, and the circuit breaker stops an outage holding threads (SPEC-025). Mail is the same shape — `CredentialMailDispatcher` swallows a send failure so registration still answers `202`
V16.5.3	met	fail-closed by construction: `ValidationBehaviour` throws before a handler runs, the audit behaviour rolls its row back with the write it describes, and the start-up guards refuse to boot without `DATABASE_URL`, the JWT settings or a mail sender

What this evidence pass changed about the claim

Three requirements moved from "presumed fine" to **named gaps**, each with a register row: there is no authenticated change-password endpoint (**T-31**), nothing screens a password against breached or context-specific words (**T-32**), and the logs are neither protected nor shipped (**T-33**). None is a regression; each is a committed requirement that was never built, and each is now written down where a reader will find it.

Related

[[owasp-index]] · [[owasp-top10-checklist]] · [[threat-register]] · [[ADR-0009-code-quality-gates]]